Nexora Technologies Pvt. Ltd.

Cybersecurity, Risk, Privacy & Compliance Handbook

Document ID: NXR-SEC-004
Document Type: Corporate Security, Risk, Privacy & Compliance Handbook
Classification: Internal
Version: 4.0
Effective Date: 1 October 2026
Document Owner: Chief Information Security Officer
Executive Sponsor: Arjun Malhotra, Chief Information Security Officer
Approved By: Security Governance Committee
Review Cycle: Annual, with interim updates following material regulatory, organizational, or technology changes

---

1. Purpose, Scope & Security Philosophy

a. Purpose

Nexora Technologies Pvt. Ltd. operates technology platforms, delivers digital transformation services, manages customer information, develops software, processes analytical datasets, and operates cloud infrastructure across multiple geographies.

The purpose of this handbook is to establish the company's operating framework for:

I. Cybersecurity
II. Information protection
III. Privacy and personal-data management
IV. Technology and operational risk
V. Regulatory and contractual compliance
VI. Security incident management
VII. Third-party security
VIII. Security governance and assurance

Security is treated as a business responsibility rather than an isolated IT function.

Nexora's security philosophy is based on the principle:

> *Protect information according to its value, manage risk according to its impact, and design security into every business and technology decision.*

b. Scope

This handbook applies to:

I. All Nexora employees
II. Contractors and consultants
III. Interns and fixed-term personnel
IV. Corporate IT systems
V. Customer-facing platforms
VI. Cloud infrastructure
VII. Software development environments
VIII. Data and analytics platforms
IX. Corporate applications
X. Third-party services handling Nexora information
XI. Customer environments operated or supported by Nexora where contractual obligations require compliance

The requirements apply regardless of whether systems are operated from Bengaluru, Pune, Hyderabad, London, customer premises, public cloud environments, or approved remote locations.

c. Security Objectives

Nexora maintains five primary security objectives.

Objective	Description
Confidentiality	Information is accessible only to authorized individuals and systems
Integrity	Information and systems remain accurate, trustworthy, and protected against unauthorized modification
Availability	Critical services remain available within approved business requirements
Privacy	Personal information is collected, processed, retained, and deleted appropriately
Accountability	Security actions can be attributed to authorized identities and reviewed when necessary

d. Relationship With Corporate Principles

Security supports Nexora's broader operating principle:

Understand the problem. Protect the information. Build responsibly. Deliver measurable value. Learn continuously.

Security teams therefore work closely with Engineering, Data & AI, Cloud & Infrastructure, Corporate IT, Customer Delivery, Legal, People Operations, Procurement, Finance, and Executive Leadership.

2. Security Organization & Governance

a. Security Organization

Nexora's security function is led by the Chief Information Security Officer.

The security organization consists of:

I. Security Leadership
II. Security Governance and Risk
III. Security Operations
IV. Application and Product Security
V. Cloud and Infrastructure Security
VI. Identity and Access Management
VII. Privacy and Data Protection
VIII. Security Assurance
IX. Third-Party Security

The organization works with the approximately 1,180-person Nexora workforce through designated security responsibilities embedded in business and technology teams.

b. Chief Information Security Officer

The CISO is accountable for:

I. Enterprise cybersecurity strategy
II. Security policy and standards
III. Security risk management
IV. Security incident response
V. Security investment planning
VI. Security governance reporting
VII. Regulatory security obligations
VIII. Executive-level security escalation

The CISO reports material cybersecurity risks to the Executive Leadership Council and Security Governance Committee.

c. Security Governance Committee

The Security Governance Committee meets monthly.

Standing participants include:

Role	Responsibility
CISO	Chair and security accountability
CTO	Technology risk
CFO representative	Financial and investment risk
Legal representative	Regulatory and contractual matters
Privacy representative	Personal-data protection
Corporate IT representative	Endpoint and enterprise technology
Cloud representative	Infrastructure security
Engineering representative	Application security
Customer Delivery representative	Customer obligations

The committee reviews:

I. High and critical security risks
II. Security incidents
III. Vulnerability trends
IV. Access-review results
V. Audit findings
VI. Third-party security risks
VII. Security exceptions
VIII. Compliance status
IX. Security investment requirements

d. Security Decision Rights

Security authority is divided according to impact.

Decision	Primary Authority
Standard security configuration	Security Engineering
Employee access exception	IAM + Security
Critical privileged access	CISO delegate
High-risk vendor exception	CISO + Procurement + Legal
Critical vulnerability extension	CISO
Material customer security incident	CISO + Customer Delivery + Legal
Regulatory notification decision	Legal + Privacy + CISO
Enterprise security policy	Security Governance Committee

3. Information Security Principles & Classification

a. Core Security Principles

Nexora follows the following principles.

I. Least Privilege

Users receive only the access necessary to perform approved responsibilities.

II. Defense in Depth

Critical systems must not depend on a single security control.

III. Secure by Default

New systems should begin with the strongest practical security configuration rather than relying on users to enable protections later.

IV. Zero Trust

Authentication and authorization decisions are based on identity, device state, resource sensitivity, context, and risk rather than network location alone.

V. Continuous Verification

Security controls are periodically tested rather than assumed to remain effective indefinitely.

VI. Data Minimization

Systems should collect and retain only information required for legitimate business purposes.

VII. Accountability

Security-relevant activities must be attributable to individual or controlled service identities.

b. Information Classification

Nexora uses four information classifications.

Classification	Typical Examples	Handling
Public	Published website content, approved press releases	May be publicly distributed
Internal	Internal procedures, ordinary operational documents	Nexora workforce only
Confidential	Customer proposals, internal financial reports, source-code repositories	Authorized workforce and approved third parties
Restricted	Credentials, encryption keys, sensitive personal data, security investigations	Explicitly authorized personnel only

c. Public Information

Public information may include:

I. Published product descriptions
II. Approved marketing content
III. Public job advertisements
IV. Published corporate announcements
V. Approved technical articles

Employees must not classify information as Public merely because they believe disclosure would be harmless.

d. Internal Information

Internal information is intended for ordinary Nexora business operations.

Examples include:

I. Internal process documentation
II. General training materials
III. Organization charts

IV. Non-sensitive operational procedures
V. Internal meeting notes

Internal information must not be automatically published externally.

e. Confidential Information

Confidential information requires controlled access.

Examples include:

I. Customer contracts
II. Product roadmaps
III. Financial forecasts
IV. Commercial proposals
V. Non-public source code
VI. Internal architecture documentation
VII. Employee compensation information

f. Restricted Information

Restricted information receives the strongest controls.

Examples include:

I. Passwords
II. API keys
III. Private encryption keys
IV. Security investigation records
V. Authentication secrets
VI. Sensitive personal information
VII. Certain customer production datasets
VIII. Unpublished vulnerability information

Restricted information must not be stored in public repositories, personal cloud storage, unsecured spreadsheets, or personal messaging applications.

---

4. Identity, Authentication & Access Management

a. Identity Management

Nexora Identity is the enterprise identity platform used for centralized authentication and access management.

Every employee requiring access to corporate systems receives an individual identity.

Shared employee accounts are prohibited unless a documented technical limitation exists and compensating controls have been approved.

b. Authentication Requirements

Multi-factor authentication is mandatory for:

I. Privileged accounts
II. Corporate cloud environments
III. Production administrative interfaces
IV. Security platforms
V. Financial systems
VI. Customer systems where contractually required
VII. Remote access to restricted corporate resources

The target is:

100% MFA coverage for privileged identities.

c. Password Requirements

Where passwords remain necessary:

I. Passwords must be unique to Nexora systems
II. Password reuse across corporate and personal services is prohibited
III. Passwords must not be stored in plaintext
IV. Credentials must not be sent through ordinary email
V. Passwords must not be committed to source repositories
VI. Suspected credential compromise must be reported immediately

Approved password-management mechanisms must be used for managed credentials.

d. Privileged Access

Privileged accounts include identities capable of:

I. Changing production configuration
II. Managing cloud resources
III. Creating administrative identities
IV. Accessing security infrastructure
V. Changing database permissions
VI. Modifying security policies

Privileged access must be:

I. Individually attributable
II. MFA protected
III. Time-limited where technically practical
IV. Logged
V. Periodically reviewed

e. Access Review

Critical applications undergo formal access review at least quarterly.

The review verifies:

I. Current employment status
II. Current role
III. Business justification
IV. Manager approval

V. Privilege level
VI. Separation-of-duty conflicts
VII. Dormant access

Access that is no longer required must be removed.

f. Joiner Access

When a new employee joins Nexora:

1. People Operations creates or confirms the employee record in Nexora PeopleHub.
2. Identity Management creates the corporate identity.
3. The manager submits required application access.
4. Application owners approve sensitive access.
5. Corporate IT provisions approved endpoint equipment.
6. Security controls are validated.
7. The employee completes mandatory security training.

g. Mover Access

Role changes must trigger an access review.

When an employee changes department, manager, location, or job responsibilities:

I. Existing access is evaluated
II. New access is approved
III. Unnecessary privileges are removed
IV. Privileged roles are revalidated
V. Customer-specific access is reassessed

h. Leaver Access

For standard departures, corporate access should be disabled according to the approved People Operations departure workflow.

For involuntary or security-sensitive departures, access may be disabled immediately upon authorization.

The leaver process covers:

I. Nexora Identity
II. Nexora Workspace
III. Nexora ServiceDesk
IV. Cloud accounts
V. Source-code systems
VI. Customer environments
VII. VPN and remote access
VIII. SaaS applications
IX. Physical access

5. Security Awareness, Human Risk & Acceptable Use

a. Security Training

Security awareness training is mandatory for all employees and applicable contractors.

Nexora's annual completion target is:

At least 98% of eligible personnel.

Training covers:

I. Phishing
II. Password security
III. MFA
IV. Data classification
V. Privacy
VI. Social engineering
VII. Secure remote work
VIII. Incident reporting
IX. Acceptable technology use
X. Safe handling of customer information

b. New-Hire Security Training

New employees must complete baseline security training within the defined onboarding period.

Training includes practical scenarios such as:

I. Identifying a fraudulent login page
II. Handling a suspicious attachment
III. Reporting a lost laptop
IV. Recognizing an unusual MFA request
V. Protecting customer data
VI. Reporting accidental disclosure

c. Phishing Simulation

Security Operations conducts controlled phishing simulations throughout the year.

Metrics include:

Metric	Target
Simulation participation	≥95%
Credential submission rate	<3%
Reporting rate	≥70%
Repeat-risk population	<2%

Employees who repeatedly fail simulations may receive targeted security coaching.

d. Social Engineering

Employees must verify unusual requests involving:

I. Money transfers
II. Password resets
III. MFA changes
IV. Customer data
V. Source-code access
VI. Executive impersonation
VII. Vendor bank-account changes

Urgency is not evidence of legitimacy.

e. Acceptable Use

Corporate technology must primarily be used for authorized business purposes.

Employees must not:

I. Disable security software without approval
II. Install unapproved administrative tools
III. Share corporate credentials
IV. Store Restricted information on personal devices
V. Circumvent security controls
VI. Use unauthorized file-sharing services for customer information
VII. Upload confidential company information to unapproved AI services

---

6. Security Engineering & Secure Software Development

a. Security Integration With Engineering

Security requirements are integrated into the software lifecycle.

Engineering teams must consider security during:

I. Product discovery
II. Architecture
III. Design
IV. Development
V. Testing
VI. Deployment
VII. Operations
VIII. Retirement

Security works with Engineering under the software standards established in the Engineering handbook.

b. Threat Modeling

Threat modeling is required for:

I. New critical services
II. Significant architecture changes
III. Systems processing Restricted information
IV. Internet-facing applications with elevated risk
V. Authentication systems
VI. Financial transaction systems

Threat modeling should identify:

I. Assets
II. Trust boundaries
III. Threat actors
IV. Attack paths
V. Security controls
VI. Residual risk

c. Secure Coding

Developers must protect against common classes of vulnerabilities, including:

I. Injection
II. Broken authentication
III. Broken authorization
IV. Sensitive-data exposure
V. Insecure deserialization
VI. Security misconfiguration
VII. Server-side request forgery
VIII. Cross-site scripting
IX. Dependency vulnerabilities
X. Improper error handling

d. Code Scanning

Production-bound software should undergo appropriate automated security checks.

Controls may include:

I. Static application security testing
II. Software composition analysis
III. Secret detection
IV. Container image scanning
V. Infrastructure-as-code scanning
VI. Dynamic application testing

Critical findings must be remediated before production release unless an approved security exception exists.

e. Security Review Gates

Security review may be required before production deployment when a system:

I. Processes sensitive personal data
II. Provides administrative functionality
III. Exposes high-risk APIs
IV. Integrates with external identity providers
V. Handles financial information
VI. Introduces new trust boundaries

7. Vulnerability, Patch & Configuration Management

a. Vulnerability Management

Nexora maintains a risk-based vulnerability remediation model.

Severity	Target Remediation
Critical	7 calendar days
High	14 calendar days
Medium	30 calendar days
Low	90 calendar days

The targets apply unless documented compensating controls or an approved exception exist.

b. Vulnerability Prioritization

Severity alone does not determine business priority.

Security evaluates:

I. Exploitability
II. Internet exposure
III. Asset criticality
IV. Data sensitivity
V. Active exploitation
VI. Availability of mitigations
VII. Customer impact
VIII. Regulatory implications

c. Emergency Vulnerabilities

An emergency security response may be initiated when:

I. A critical vulnerability is actively exploited
II. A public exploit is readily available
III. A critical Nexora service is directly exposed
IV. Sensitive customer information may be at risk
V. A security advisory requires immediate action

Emergency remediation may involve:

I. Temporary service restrictions
II. Emergency patching
III. Configuration changes
IV. Firewall controls
V. Feature disabling
VI. Temporary credential rotation

d. Patch Compliance

Security and Corporate IT track patch compliance across managed endpoints.

Target compliance:

Device Category	Target
Standard corporate endpoints	≥95%
Privileged administrative endpoints	≥98%
Critical infrastructure	≥98%
Internet-facing infrastructure	≥98%

e. Configuration Baselines

Approved security baselines exist for:

I. Corporate laptops
II. Cloud workloads
III. Container images
IV. Operating systems
V. Databases
VI. Network devices
VII. Identity platforms

Unauthorized deviations must be documented and reviewed.

---

8. Cloud, Network, Endpoint & Infrastructure Security

a. Cloud Security

Nexora primarily operates production cloud workloads on Google Cloud Platform.

Security controls cover:

I. Identity
II. Network segmentation
III. Encryption
IV. Logging
V. Monitoring
VI. Vulnerability management

VII. Configuration management
VIII. Backup protection
IX. Administrative access

b. Cloud Environment Separation

Development, Test, Staging, and Production environments must remain appropriately separated.

Production credentials must not be reused in development environments.

Production data must not be copied into development environments unless an approved data-protection mechanism has been applied.

c. Network Segmentation

Network architecture should separate:

I. Public services
II. Application services
III. Data services
IV. Administrative interfaces
V. Security services
VI. Development resources

Access between zones must be based on documented requirements.

d. Internet-Facing Systems

Internet-facing systems require:

I. Secure authentication where applicable
II. Vulnerability scanning
III. TLS encryption
IV. Logging
V. Monitoring
VI. Rate limiting where appropriate
VII. Incident response ownership

e. Endpoint Protection

Corporate endpoints must use approved security controls.

These may include:

I. Endpoint detection and response
II. Disk encryption
III. Screen lock
IV. Security updates
V. Device management
VI. Malware protection
VII. Centralized logging

f. Lost or Stolen Devices

A lost corporate device must be reported immediately through Nexora ServiceDesk or the security incident process.

Corporate IT may:

I. Lock the device
II. Revoke sessions
III. Disable credentials
IV. Remotely erase data where supported
V. Investigate potentially exposed information

---

9. Data Protection & Privacy

a. Privacy Principles

Nexora processes personal information according to applicable laws, contracts, and legitimate business requirements.

Core principles include:

I. Purpose limitation
II. Data minimization
III. Accuracy
IV. Transparency
V. Retention limitation
VI. Security
VII. Accountability

b. Personal Data Categories

Depending on the business process, Nexora may process:

I. Employee information
II. Customer contact information
III. User account information
IV. Authentication information
V. Service usage information
VI. Support records
VII. Transaction-related information
VIII. Analytics information

Not every system is authorized to process every category.

c. Sensitive Data

Sensitive or high-impact personal information requires stronger controls.

Examples may include:

I. Government identification information
II. Financial account information
III. Authentication credentials
IV. Health-related employee information
V. Certain biometric information
VI. Other legally protected categories

d. Data Collection

Business teams must identify:

I. What information is collected
II. Why it is collected
III. Who uses it
IV. Where it is stored
V. How long it is retained
VI. Who it is shared with

Collection of information without a documented business purpose should be avoided.

e. Data Retention

Retention periods must reflect:

I. Legal requirements
II. Contractual requirements
III. Operational requirements
IV. Security requirements
V. Customer instructions

Data must not be retained indefinitely simply because storage is inexpensive.

f. Data Deletion

When retention requirements expire, information should be securely deleted, anonymized, or otherwise rendered unavailable for the original purpose.

Deletion must consider:

I. Primary databases
II. File stores
III. Backups
IV. Analytics platforms
V. Caches
VI. Export files

Backup deletion may follow the established backup lifecycle rather than immediate deletion from every historical copy.

g. Cross-Border Processing

Nexora operates across India, the UK, Europe, and North America.

Cross-border data processing must consider:

I. Applicable privacy laws
II. Customer contractual requirements
III. Data-transfer mechanisms
IV. Storage location
V. Subprocessor involvement
VI. Security requirements

Legal and Privacy teams must be consulted for material cross-border arrangements.

---

10. Security Incident Response & Threat Management

a. Incident Definition

A security incident is an event that may compromise:

I. Confidentiality
II. Integrity
III. Availability
IV. Privacy
V. Authentication
VI. Regulatory compliance

Examples include:

I. Malware infection
II. Credential compromise
III. Unauthorized access
IV. Data disclosure
V. Phishing
VI. Cloud misconfiguration
VII. Lost device
VIII. Suspicious administrative activity

b. Incident Severity

Nexora uses four operational severity levels.

Severity	Description	Initial Response Target
Sev1	Critical enterprise/customer impact	15 minutes
Sev2	Major security impact	30 minutes
Sev3	Significant but contained issue	4 business hours
Sev4	Low-impact security event	1 business day

c. Incident Lifecycle

Security incidents follow:

I. Detection
II. Triage
III. Classification
IV. Containment
V. Investigation
VI. Eradication
VII. Recovery
VIII. Communication
IX. Lessons learned

d. Incident Commander

For Sev1 and major Sev2 incidents, an Incident Commander is assigned.

The Incident Commander coordinates:

I. Security
II. Engineering
III. Cloud & Infrastructure
IV. Corporate IT
V. Customer Delivery
VI. Legal
VII. Communications
VIII. Executive stakeholders

e. Evidence Preservation

Security investigations may require preservation of:

I. Authentication logs
II. Cloud audit logs
III. Endpoint telemetry
IV. Network logs
V. Application logs
VI. Email evidence
VII. Configuration history
VIII. Relevant source-code changes

Evidence must be handled in a manner that maintains integrity and limits unauthorized access.

f. Security Communications

Only authorized personnel may communicate externally about material security incidents.

Customer communications must be coordinated with Customer Delivery and Legal.

Regulatory notifications are determined by Legal and Privacy based on applicable obligations and facts established during investigation.

11. Security Operations, Monitoring & Detection

a. Security Operations

Security Operations monitors enterprise and production environments using Nexora Sentinel and approved supporting systems.

Monitoring may cover:

I. Authentication anomalies
II. Privilege escalation
III. Suspicious network activity
IV. Endpoint threats
V. Cloud configuration changes
VI. Malware indicators
VII. Data-access anomalies
VIII. Security-policy violations

b. Security Logging

Security-relevant systems must generate sufficient logs to support:

I. Detection
II. Investigation
III. Troubleshooting
IV. Audit
V. Compliance

Security logs are generally retained for at least 90 days unless a longer period is required.

c. High-Risk Events

Events receiving elevated monitoring priority include:

I. Privileged login from unusual locations
II. Multiple failed authentication attempts
III. Administrative policy changes
IV. Creation of unexpected service accounts
V. Disabling of security controls
VI. Unusual bulk data access
VII. Suspicious cloud API activity

d. Alert Management

Security Operations prioritizes alerts according to:

I. Asset criticality
II. Threat confidence
III. User privilege
IV. Data sensitivity
V. Attack progression
VI. Potential business impact

Automated alerts are not treated as confirmed incidents until appropriate triage is performed.

e. Detection Metrics

Security Operations tracks:

Metric	Target
Critical alert triage	≤15 minutes
High alert triage	≤30 minutes
Critical detection coverage	≥95%
Security log availability	≥99%
Critical security-control monitoring	≥98%

12. Third-Party, Supplier & Customer Security

a. Third-Party Security

Third parties may introduce security risk through:

I. Data access
II. Software dependencies
III. Infrastructure access
IV. Support services
V. Managed services
VI. Physical access

Supplier security requirements are determined using risk-based classification.

b. Vendor Risk Tiers

Tier	Example	Assessment
Tier 1	Critical infrastructure or Restricted-data provider	Enhanced
Tier 2	Important business or customer-data provider	Standard
Tier 3	Low-risk operational provider	Basic

c. Security Due Diligence

Depending on risk, assessments may examine:

I. Security certifications
II. Incident history
III. Access controls
IV. Encryption

V. Business continuity
VI. Privacy controls
VII. Vulnerability management
VIII. Subprocessors
IX. Data residency
X. Contractual obligations

d. Contractual Security Requirements

Material vendors may be required to accept:

I. Confidentiality obligations
II. Security requirements
III. Breach notification requirements
IV. Data-processing provisions
V. Audit rights
VI. Subprocessor controls
VII. Data return or deletion requirements

e. Vendor Access

Third-party access must be:

I. Business justified
II. Approved
III. Time limited where practical
IV. Attributable
V. Monitored according to risk
VI. Removed when no longer required

f. Customer Security Commitments

Customer-specific security commitments may exceed Nexora's baseline requirements.

Contractual requirements must be reviewed before commitment and assigned to accountable owners.

Customer Delivery, Legal, Security, Engineering, and Cloud teams collaborate on material commitments.

---

13. Enterprise Risk Management & Compliance

a. Security Risk Framework

Nexora evaluates security risk based on:

Risk = Likelihood × Impact

Each factor is scored from 1 to 5.

This produces a risk score from 1 to 25.

Score	Rating
1–4	Low
5–9	Moderate
10–16	High
17–25	Critical

b. Risk Treatment

Risk owners may choose:

I. Mitigate
II. Transfer
III. Avoid
IV. Accept

Risk acceptance must be proportional to the impact.

Critical risks generally require executive visibility.

c. Risk Register

Security maintains a centralized risk register containing:

I. Risk ID
II. Description
III. Asset/process
IV. Risk owner
V. Likelihood
VI. Impact
VII. Risk score
VIII. Treatment
IX. Mitigation actions
X. Target date
XI. Residual risk
XII. Approval status

d. Example Risk Record

Risk ID: NXR-RISK-2026-041

Risk: Legacy customer integration uses authentication controls below the current enterprise baseline.

Likelihood: 4

Impact: 4

Inherent Risk: 16 — High

Treatment: Mitigate

Owner: Engineering Platform Lead

Mitigation: Replace legacy authentication mechanism and introduce centralized identity controls.

Target Date: 15 December 2026

Residual Risk Target: ≤6

e. Compliance Management

Compliance obligations may arise from:

I. Applicable laws
II. Customer contracts
III. Industry standards
IV. Internal policies
V. Regulatory requirements
VI. Security commitments

The Legal, Privacy, Security, Finance, and operational teams collaborate to maintain compliance.

f. Audit Management

Audit activities may include:

I. Internal audits
II. Customer audits
III. Independent assessments
IV. Regulatory examinations
V. Certification assessments
VI. Security reviews

Findings must have:

I. Named owner
II. Severity
III. Corrective action
IV. Target completion date
V. Evidence of closure

---

14. Security Metrics, Exceptions, Assurance & Reference Procedures

a. Security Performance Dashboard

The CISO reviews security performance monthly.

Core metrics include:

Metric	Target
Security training completion	≥98%

Metric	Target
Privileged MFA	100%
Critical access review completion	100%
Critical vulnerability remediation	≥95% within SLA
High vulnerability remediation	≥95% within SLA
Critical endpoint patch compliance	≥98%
Security incident Sev1 response	≤15 minutes
Critical security alert triage	≤15 minutes
Phishing credential submission	<3%
Security exceptions past expiry	0

b. Security Exceptions

A security exception is required when an approved business or technical need prevents compliance with a mandatory security requirement.

Exception requests must include:

I. Requirement being bypassed
II. Business justification
III. Affected system
IV. Data classification
V. Risk assessment
VI. Compensating controls
VII. Requested duration
VIII. Responsible owner

c. Exception Duration

Exceptions should be temporary.

Standard exception periods should not exceed 180 days without formal reapproval.

Critical-risk exceptions require senior security approval.

Expired exceptions must not be treated as automatically renewed.

d. Security Assurance

Security Assurance performs periodic validation of important controls.

Activities may include:

I. Access reviews
II. Configuration reviews
III. Vulnerability assessments
IV. Security-control testing

V. Evidence validation
VI. Incident-response exercises
VII. Disaster-recovery exercises
VIII. Vendor assessments

e. Control Testing

Control tests evaluate both:

Design effectiveness — whether the control is appropriately designed.

Operating effectiveness — whether the control actually operates as intended.

Failed controls require remediation or documented risk treatment.

f. Security Exercises

Nexora conducts periodic exercises such as:

I. Phishing simulations
II. Incident-response tabletop exercises
III. Cloud compromise scenarios
IV. Lost-device scenarios
V. Data-disclosure scenarios
VI. Business-continuity exercises

Exercise findings are assigned owners and target dates.

g. Annual Security Planning

The security organization prepares an annual security plan covering:

I. Security priorities
II. Major risks
III. Planned investments
IV. Workforce requirements
V. Technology improvements
VI. Compliance activities
VII. Security awareness initiatives
VIII. Incident-readiness objectives

Security priorities are reviewed with the Executive Leadership Council.

---

15. Security Procedures & Operational Checklists

a. New Application Security Checklist

Before a new application enters production, the responsible team should confirm:

- [ ] Business owner identified
- [ ] Technical owner identified

- [ ] Data classification completed
- [ ] Authentication mechanism approved
- [ ] Authorization model documented
- [ ] Secrets stored using approved mechanisms
- [ ] Encryption requirements evaluated
- [ ] Logging implemented
- [ ] Monitoring configured
- [ ] Vulnerability scanning completed
- [ ] Dependency risks reviewed
- [ ] Threat modeling completed where required
- [ ] Backup requirements established
- [ ] Incident ownership assigned
- [ ] Security exceptions documented
- [ ] Production approval completed

b. Employee Access Checklist

- [ ] Employee record exists in PeopleHub
- [ ] Corporate identity created
- [ ] Manager approval completed
- [ ] Application access approved
- [ ] Privileged access separately approved
- [ ] MFA enabled
- [ ] Endpoint security active
- [ ] Security training completed
- [ ] Customer-specific access reviewed where applicable

c. Security Incident Checklist

Detection

- [ ] Alert received
- [ ] Initial event validated
- [ ] Affected asset identified
- [ ] User or service identity identified

Triage

- [ ] Severity assigned
- [ ] Business impact estimated
- [ ] Data exposure considered
- [ ] Customer impact considered

Containment

- [ ] Compromised identity isolated

- [ ] Malicious access blocked
- [ ] Affected endpoint isolated
- [ ] Vulnerable service mitigated

Investigation

- [ ] Logs preserved
- [ ] Timeline constructed
- [ ] Attack vector identified
- [ ] Scope determined

Recovery

- [ ] Threat removed
- [ ] Credentials rotated where required
- [ ] Systems restored
- [ ] Monitoring increased

Closure

- [ ] Root cause documented
- [ ] Corrective actions assigned
- [ ] Stakeholders informed
- [ ] Lessons learned recorded

d. Vendor Security Checklist

Before approving a high-risk vendor:

- [ ] Business owner identified
- [ ] Data types documented
- [ ] Access requirements documented
- [ ] Security assessment completed
- [ ] Privacy assessment completed where required
- [ ] Contract reviewed
- [ ] Breach notification terms reviewed
- [ ] Subprocessor requirements reviewed
- [ ] Data retention requirements documented
- [ ] Exit and deletion requirements documented

---

16. Security Scenarios & Reference Cases

a. Example: Compromised Employee Credentials

Case ID: SEC-CASE-2026-017

An employee reports receiving an MFA approval request they did not initiate.

Security Operations determines that the employee's password may have been compromised.

The response includes:

I. Temporary account restriction
II. Session revocation
III. Password reset
IV. MFA validation
V. Authentication-log analysis
VI. Endpoint review
VII. Investigation of accessed resources
VIII. Assessment of possible data exposure

If evidence indicates customer information was accessed, Customer Delivery and Legal are engaged.

b. Example: Exposed Cloud Credential

Case ID: SEC-CASE-2026-024

A secret-detection system identifies a cloud credential in a development repository.

Immediate actions include:

I. Credential revocation
II. Replacement credential generation
III. Repository review
IV. Access-log analysis
V. Determination of credential usage
VI. Secret-removal remediation
VII. Root-cause analysis

The incident is escalated if the credential had production privileges.

c. Example: Phishing Campaign

Case ID: SEC-CASE-2026-031

A targeted phishing campaign impersonates a Nexora executive and requests urgent financial information.

Security Operations blocks known indicators.

Finance validates whether any payment or bank-detail changes occurred.

People Operations and Security notify affected employees.

If credentials were submitted, impacted accounts are investigated and secured.

d. Example: Customer Data Misdelivery

Case ID: SEC-CASE-2026-039

An employee accidentally sends a customer report to an unauthorized external recipient.

The employee reports the incident immediately.

Security and Privacy evaluate:

I. Information classification
II. Recipient identity
III. Data volume
IV. Data sensitivity
V. Whether the message was opened
VI. Contractual requirements
VII. Applicable notification requirements

The event is documented even if no evidence indicates that the recipient accessed the attachment.

---

17. Security Responsibilities by Function

a. Executive Leadership

Executive Leadership is responsible for:

I. Supporting security strategy
II. Reviewing material risks
III. Funding critical security requirements
IV. Ensuring security accountability

b. Engineering

Engineering is responsible for:

I. Secure software development
II. Vulnerability remediation
III. Secure architecture
IV. Security testing
V. Production security ownership

c. Cloud & Infrastructure

Cloud & Infrastructure is responsible for:

I. Cloud security controls
II. Network security
III. Infrastructure hardening
IV. Patch management
V. Backup security
VI. Infrastructure monitoring

d. Corporate IT

Corporate IT is responsible for:

I. Endpoint management
II. Device security
III. SaaS administration
IV. Employee technology support
V. Secure onboarding and offboarding

e. Data & AI

Data & AI teams are responsible for:

I. Appropriate data access
II. Dataset classification
III. Model security
IV. AI-system safeguards
V. Protection of analytical information

AI-related controls must also align with the company's AI Governance Committee.

f. People Operations

People Operations supports:

I. Joiner workflows
II. Mover workflows
III. Leaver workflows
IV. Employee records
V. Security training coordination

g. Procurement

Procurement supports:

I. Vendor due diligence
II. Contractual security requirements
III. Vendor renewal reviews
IV. Supplier risk escalation

h. Legal & Privacy

Legal and Privacy support:

I. Regulatory interpretation
II. Contractual obligations
III. Data-protection requirements
IV. Incident notification decisions
V. Privacy assessments

i. All Employees

Every employee is responsible for:

I. Protecting corporate information
II. Following security policies
III. Reporting suspicious activity
IV. Protecting credentials
V. Completing required training
VI. Using approved systems
VII. Reporting incidents promptly

Appendix A. Security Classification Quick Reference

Information	Classification
Published Nexora website content	Public
Internal team procedure	Internal
Non-public product roadmap	Confidential
Customer contract	Confidential
Source code	Confidential
Password	Restricted
Private encryption key	Restricted
Security investigation	Restricted
Sensitive personal information	Restricted

Appendix B. Security Response Targets

Activity	Target
Sev1 security response	15 minutes
Sev2 security response	30 minutes
Sev3 response	4 business hours
Sev4 response	1 business day
Critical vulnerability	7 days
High vulnerability	14 days
Medium vulnerability	30 days
Low vulnerability	90 days
Critical access review	Quarterly

Activity	Target
Privileged MFA	100%
Security training	≥98%

Appendix C. Security Governance Calendar

Activity	Frequency
Security Operations review	Weekly
Security metrics review	Monthly
Security Governance Committee	Monthly
Critical access review	Quarterly
Vendor risk review	Risk-based
Incident-response exercise	At least annually
Security policy review	Annually
Enterprise risk review	Quarterly
Security strategy review	Annually

Appendix D. Security Record Identifiers

Nexora uses structured identifiers for security records.

Examples include:

Identifier	Purpose
NXR-SEC-004	Security handbook
NXR-RISK-2026-041	Enterprise security risk
SEC-CASE-2026-017	Security case
VUL-2026-00871	Vulnerability record
SEC-EXC-2026-012	Security exception
AUD-SEC-2026-004	Security audit
VEND-SEC-2026-031	Vendor security assessment

Identifiers do not themselves determine information classification. The underlying record classification must be applied separately.

Appendix E. Related Nexora Standards

Security requirements must be interpreted together with applicable corporate standards.

Relevant documents include:

Document	Relationship
NXR-CORP-001	Company, People & Corporate Governance
NXR-TECH-002	Product, Engineering & Software Development
NXR-INFRA-003	Cloud, Infrastructure & IT
NXR-DATA-005	Data, Analytics, AI & Automation
NXR-DEL-006	Customer Delivery & Customer Success
NXR-COM-007	Sales, Marketing, Finance & Procurement
NXR-OPS-008	Legal, Operations, Continuity & Knowledge

Where requirements conflict, the stricter applicable security or contractual requirement should be followed unless an authorized exception exists.

Appendix F. Security Policy Statement

Nexora Technologies recognizes information and technology as critical business assets.

Every employee, contractor, and business function contributes to protecting those assets.

Security is not limited to firewalls, passwords, monitoring tools, or compliance assessments. It is the combined result of responsible decisions across people, processes, technology, suppliers, products, and leadership.

Nexora therefore expects every member of the organization to:

Understand the information they handle.

Protect it according to its classification.

Use only authorized systems and access.

Report suspicious activity quickly.

Build and operate technology securely.

Treat privacy as a business responsibility.

Manage risk transparently.

Learn from incidents and continuously improve.

The objective is not to eliminate every possible risk. The objective is to understand risk, reduce unnecessary exposure, maintain resilience, and ensure that Nexora can continue delivering trusted technology services to its employees, customers, partners, and communities.